

# SEHHA

Documentation technique



*Plateforme IA hospitalière intégrée pour le  
pré-triage médical et la gestion du flux patient*

**Équipe** Équipe SEHHA

BADO Yipenè Ange Cenacle

BELEMSIGRI Windyam Juste Yannel

KAMBOU Sié Serginho Hector

KABA Ibrahima

KONKOBO W. F. Cedric

## Table des matières

|          |                                                                      |           |
|----------|----------------------------------------------------------------------|-----------|
| <b>1</b> | <b>Résumé exécutif</b>                                               | <b>3</b>  |
| <b>2</b> | <b>Contexte et problématique</b>                                     | <b>3</b>  |
| 2.1      | Le constat . . . . .                                                 | 3         |
| 2.2      | L'opportunité . . . . .                                              | 4         |
| 2.3      | Le principe directeur de SEHHA . . . . .                             | 4         |
| <b>3</b> | <b>Vision produit et périmètre</b>                                   | <b>4</b>  |
| 3.1      | Deux modules complémentaires . . . . .                               | 4         |
| 3.2      | Les cinq rôles . . . . .                                             | 4         |
| 3.3      | Périmètre de l'MVP . . . . .                                         | 5         |
| <b>4</b> | <b>Fonctionnalités et parcours utilisateurs</b>                      | <b>5</b>  |
| 4.1      | F1. Triage médical par intelligence artificielle . . . . .           | 5         |
| 4.2      | F2. Rendez-vous en ligne . . . . .                                   | 6         |
| 4.3      | F3. Dossier médical électronique . . . . .                           | 7         |
| 4.4      | F4. Authentification des soignants (double facteur) . . . . .        | 7         |
| 4.5      | F5. Ordonnance numérique infalsifiable . . . . .                     | 7         |
| 4.6      | Fonctions complémentaires . . . . .                                  | 8         |
| <b>5</b> | <b>Architecture technique</b>                                        | <b>8</b>  |
| 5.1      | Vue d'ensemble . . . . .                                             | 8         |
| 5.2      | API centrale . . . . .                                               | 9         |
| 5.3      | Moteur de triage . . . . .                                           | 10        |
| 5.4      | Service d'analyse IA . . . . .                                       | 10        |
| 5.5      | Interface web . . . . .                                              | 10        |
| 5.6      | Canal temps réel . . . . .                                           | 10        |
| 5.7      | Base de données . . . . .                                            | 10        |
| 5.8      | Choix de conception . . . . .                                        | 11        |
| 5.9      | Diagrammes . . . . .                                                 | 11        |
| <b>6</b> | <b>Approche IA (AI in Healthcare)</b>                                | <b>12</b> |
| 6.1      | Pourquoi un triage conversationnel . . . . .                         | 12        |
| 6.2      | Déroulé de l'entretien . . . . .                                     | 12        |
| 6.3      | Scoring de gravité . . . . .                                         | 12        |
| 6.4      | Base de connaissances médicale . . . . .                             | 12        |
| 6.5      | Dégradation gracieuse : le triage ne tombe jamais en panne . . . . . | 12        |
| 6.6      | Garde-fous cliniques . . . . .                                       | 13        |
| 6.7      | IA documentaire . . . . .                                            | 13        |
| 6.8      | Limites et éthique . . . . .                                         | 13        |
| <b>7</b> | <b>Sécurité et conformité (Cybersecurity &amp; AI)</b>               | <b>13</b> |
| 7.1      | Actifs à protéger et surface d'attaque . . . . .                     | 13        |
| 7.2      | Authentification . . . . .                                           | 14        |
| 7.3      | Autorisation (contrôle d'accès basé sur les rôles) . . . . .         | 14        |
| 7.4      | Chiffrement des données sensibles . . . . .                          | 15        |
| 7.5      | Piste d'audit à trois niveaux . . . . .                              | 15        |
| 7.6      | Durcissement applicatif . . . . .                                    | 15        |
| 7.7      | Intégrité des ordonnances . . . . .                                  | 16        |
| 7.8      | Corrections de sécurité intégrées pendant le développement . . . . . | 16        |

|          |                                                            |           |
|----------|------------------------------------------------------------|-----------|
| 7.9      | Conformité (loi 09-08 / CNDP) . . . . .                    | 16        |
| 7.10     | Renforcements prévus pour la mise en production . . . . .  | 16        |
| <b>8</b> | <b>Mise en œuvre et équipe</b>                             | <b>16</b> |
| 8.1      | Démarrage de la plateforme . . . . .                       | 16        |
| 8.2      | Organisation du dépôt . . . . .                            | 17        |
| 8.3      | Feuille de route post-hackathon . . . . .                  | 17        |
| <b>9</b> | <b>Annexes</b>                                             | <b>17</b> |
| 9.1      | Annexe A. Modèle de données (principales tables) . . . . . | 17        |
| 9.2      | Annexe B. Points d'entrée de l'API (résumé) . . . . .      | 18        |
| 9.3      | Annexe C. Matrice RBAC . . . . .                           | 19        |
| 9.4      | Annexe D. Signes d'alarme du triage (extrait) . . . . .    | 19        |
| 9.5      | Annexe E. Catalogue des événements temps réel . . . . .    | 20        |
| 9.6      | Annexe F. Glossaire . . . . .                              | 20        |

## 1 Résumé exécutif

SEHHA est une plateforme numérique pour établissements de santé qui répond à deux problèmes structurels : la surcharge des services d'urgence et la dispersion des dossiers médicaux. Elle combine deux volets :

- **Pré-triage médical assisté par IA** : un assistant conversationnel évalue la gravité d'un patient (priorités P1 à P4) avant son arrivée, l'oriente vers le bon niveau de soin, et alerte les soignants en temps réel pour les cas critiques.
- **Gestion du flux patient** : dossier médical électronique consultable et sécurisé, prise de rendez-vous en ligne, ordonnance numérique infalsifiable, tableaux de bord pour le médecin, l'infirmier et l'administration.

La plateforme est construite autour de cinq rôles (patient, infirmier, médecin, administrateur, super-administrateur) et de quatre composants : une API centrale, un moteur de triage conversationnel, un service d'analyse documentaire (reconnaissance de texte et transcription vocale), et une interface web unique.

### Positionnement compétition

SEHHA adresse simultanément les deux thèmes du Youth Nexus Cyber AI Challenge :

| Thème              | Ce que SEHHA apporte                                                                                                                                                                   |
|--------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| AI in Healthcare   | Triage conversationnel adaptatif, scoring de gravité, RAG médical, dégradation gracieuse à trois niveaux, garde-fous cliniques (allergies, cas P1)                                     |
| Cybersecurity & AI | Double authentification des soignants, chiffrement des données sensibles, piste d'audit inviolable à trois niveaux, ordonnances signées cryptographiquement, conformité à la loi 09-08 |

### État de l'MVP

Les cinq fonctionnalités cœur (triage, rendez-vous, dossier médical, authentification, ordonnance) et les fonctions complémentaires (dashboards, temps réel, analyse documentaire) sont opérationnelles de bout en bout et ont été validées par une campagne de recette couvrant les cinq rôles.

## 2 Contexte et problématique

### 2.1 Le constat

Le système de santé marocain fait face à des tensions que la digitalisation peut atténuer directement. SEHHA cible cinq problèmes concrets :

| Problème               | Description                                                                                                                                         |
|------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| Surcharge des urgences | Les urgences traitent des cas non critiques faute d'orientation en amont ; cette congestion retarde la prise en charge des vraies urgences vitales. |
| Perte de documents     | Les dossiers papier se perdent ou deviennent inaccessibles dès que le patient change d'établissement.                                               |

| Problème               | Description                                                                                                                |
|------------------------|----------------------------------------------------------------------------------------------------------------------------|
| Faible digitalisation  | La majorité des processus (rendez-vous, ordonnances, orientation) reposent encore sur le papier ou le téléphone.           |
| Manque de suivi        | Il n'existe pas de vue unifiée du parcours d'un patient entre plusieurs établissements.                                    |
| Effectifs sous tension | Le ratio soignant/patient est tendu : chaque gain d'efficacité opérationnelle a un impact direct sur la qualité des soins. |

## 2.2 L'opportunité

Deux leviers technologiques mûrs permettent d'agir :

1. **Le tri en amont.** Un outil d'aide à la décision, accessible depuis un téléphone, peut estimer la gravité d'une situation et orienter le patient vers le canal adapté (urgences, consultation spécialisée, médecine générale, téléconsultation) avant qu'il n'encombre les urgences.
2. **Le dossier partagé et sécurisé.** Un dossier médical électronique, chiffré et tracé, supprime la perte d'information et donne au soignant, en quelques secondes, l'historique dont il a besoin : allergies, antécédents, traitements en cours.

## 2.3 Le principe directeur de SEHHA

**L'intelligence artificielle assiste, elle ne décide pas.** Tout résultat de triage est signalé pour validation humaine ; aucune orientation n'a de conséquence irréversible sans intervention d'un soignant.

**La sécurité est intégrée, pas ajoutée.** Chiffrement, double authentification, piste d'audit et signature des ordonnances sont présents dès la conception, à chaque étape du parcours.

# 3 Vision produit et périmètre

## 3.1 Deux modules complémentaires

SEHHA réunit deux modules pensés pour fonctionner ensemble :

- **TriagePlus** : le pré-triage par IA avant l'arrivée aux urgences, avec entretien conversationnel, scoring de priorité, orientation et alerte temps réel des soignants.
- **PatientFlow** : la gestion du flux, avec dossier médical électronique, rendez-vous en ligne, ordonnance numérique, pilotage de la capacité (lits, stocks) et indicateurs d'activité.

## 3.2 Les cinq rôles

| Rôle    | Ce qu'il fait dans SEHHA                                                                                                                                    |
|---------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Patient | Réalise son triage, prend rendez-vous, consulte son dossier médical (lecture seule), récupère et fait vérifier ses ordonnances, met à jour ses coordonnées. |

| Rôle                 | Ce qu'il fait dans SEHHA                                                                                                                                  |
|----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Infirmier            | Consulte la file de triage, saisit les constantes vitales, pilote la capacité des lits par service et les stocks de médicaments.                          |
| Médecin              | Valide les triages, consulte et enrichit le dossier médical, réalise les consultations, émet les ordonnances (avec contrôle d'allergie), gère son agenda. |
| Administrateur       | Gère les comptes utilisateurs, consulte l'historique des actions et les indicateurs clés du service, supervise l'inventaire.                              |
| Super-administrateur | Mêmes prérogatives, avec les garde-fous de gouvernance (impossible de se désactiver soi-même ou de supprimer le dernier super-administrateur).            |

### 3.3 Périmètre de l'MVP

**Inclus et opérationnel :** triage IA conversationnel, rendez-vous en ligne, dossier médical électronique, authentification à deux facteurs des soignants, ordonnance numérique vérifiable, alertes temps réel, tableaux de bord des trois profils soignants, analyse de documents (reconnaissance de texte) et dictée vocale des comptes rendus.

**Volontairement hors périmètre (feuille de route) :**

| Fonctionnalité future                                     | Raison du report                                                             |
|-----------------------------------------------------------|------------------------------------------------------------------------------|
| Transferts inter-hôpitaux (carte de capacités temps réel) | Nécessite une coordination multi-établissements et un accord institutionnel. |
| Téléconsultation vidéo                                    | Cadre réglementaire spécifique, hors du cœur du MVP.                         |
| Interopérabilité aux standards internationaux (HL7 FHIR)  | Analyse préalable des systèmes d'information existants requise.              |
| Paiement et facturation mutuelles                         | Intégration avec les organismes payeurs.                                     |
| Carte épidémiologique nationale                           | Agrégation multi-établissements pour l'échelon ministériel.                  |
| Modèle prédictif entraîné                                 | Nécessite un volume de données réelles annotées (voir §6).                   |

## 4 Fonctionnalités et parcours utilisateurs

Chaque fonctionnalité est présentée par son objectif, son parcours pas à pas, et ses règles métier et de sécurité clés.

### 4.1 F1. Triage médical par intelligence artificielle

**Objectif.** Évaluer la gravité d'un patient à partir de ses symptômes exprimés en langage naturel, lui attribuer une priorité (P1 à P4), l'orienter, et alerter les soignants pour les cas critiques.

**Parcours patient.**

1. Le patient se connecte à l'espace patient et lance un nouveau triage.

2. Un assistant conversationnel engage un entretien : il pose des questions ciblées (motif principal, intensité de la douleur, durée, évolution, âge...), comme le ferait un soignant à l'accueil.
3. À chaque échange, l'assistant intègre le contexte médical du patient (allergies, antécédents, derniers triages) pour affiner ses questions.
4. Lorsque suffisamment d'informations sont réunies (ou dès qu'un signe d'alarme est détecté), le triage se termine.
5. Le patient reçoit : sa priorité (P1 à P4), son orientation (urgences, spécialiste, médecine générale, téléconsultation), un délai recommandé et un message explicatif.
6. Le triage est enregistré dans son dossier et apparaît dans son historique.

#### **Priorités et sémantique.**

| Priorité | Signification                           | Délai d'intervention           |
|----------|-----------------------------------------|--------------------------------|
| P1       | Urgence absolue : risque vital immédiat | Immédiat, orientation urgences |
| P2       | Très urgent : risque vital potentiel    | Sous 1 à 2 heures              |
| P3       | Urgent : état inconfortable mais stable | Sous 24 heures                 |
| P4       | Non urgent : consultation programmée    | Rendez-vous                    |

#### **Règles métier et de sécurité.**

- Un triage P1 n'ouvre pas de rendez-vous : le patient est renvoyé directement vers les urgences (message d'erreur explicite si tentative de prise de rendez-vous à partir d'un triage P1).
- Tout triage est marqué « à valider » : un médecin doit le confirmer ou le corriger. Aucune orientation n'est définitive sans validation humaine.
- Un triage P1 ou P2 déclenche une alerte temps réel sur les tableaux de bord soignants (voir §5.7).

## **4.2 F2. Rendez-vous en ligne**

**Objectif.** Permettre au patient de réserver un créneau auprès d'un médecin sans appel téléphonique.

#### **Parcours patient.**

1. Onglet « Rendez-vous » → choix d'un médecin (spécialité affichée).
2. Choix d'un créneau parmi ceux proposés pour les 7 prochains jours.
3. Saisie du motif de consultation (obligatoire).
4. Confirmation → le rendez-vous est créé au statut « en attente », en attente de confirmation par le médecin.
5. Le patient retrouve ses rendez-vous à venir et son historique dans l'onglet « Mes rendez-vous », et peut annuler un rendez-vous.

#### **Règles métier.**

- Créneaux de 30 minutes, calculés à partir de l'agenda déclaré du médecin, moins les rendez-vous déjà pris.
- Un seul rendez-vous par jour et par médecin pour un même patient.
- Blocage si le créneau vient d'être réservé par un tiers (contrôle de collision).
- Un rendez-vous issu d'un triage P1 est refusé (voir F1).
- La création, la modification et l'annulation d'un rendez-vous notifient le patient et rafraîchissent l'agenda du médecin en temps réel.

### 4.3 F3. Dossier médical électronique

**Objectif.** Donner au patient une vue lecture seule de son dossier, et au soignant autorisé une vue complète, chiffrée et tracée.

**Contenu du dossier.** Groupe sanguin, couverture (RAMED / assurance), taille, médecin traitant, allergies, antécédents et pathologies chroniques, constantes vitales (les plus récentes), historique des consultations, documents (ordonnances et documents scannés), historique des triages.

**Parcours patient (lecture seule).** Sept onglets : vue rapide, consultations, documents, constantes, urgences, scanner un document, vérifier une ordonnance. Le patient ne peut modifier que ses coordonnées et son mot de passe, jamais ses données médicales.

**Parcours soignant (lecture et écriture).**

1. Depuis la file de triage ou la recherche, le soignant ouvre le dossier d'un patient.
2. Un bandeau « Alertes critiques » affiche d'emblée les allergies et pathologies chroniques.
3. L'infirmier saisit les constantes vitales. Le médecin ajoute des consultations, des allergies, des antécédents, et émet des ordonnances.

**Règles de sécurité.**

- Les champs sensibles (identité, téléphone, allergies, description des antécédents) sont chiffrés en base ; ils ne sont déchiffrés qu'à l'affichage, pour un soignant authentifié (voir §6.4).
- Toute écriture dans le dossier est tracée (voir §6.5).
- Les réponses contenant des données patient portent l'en-tête **Cache-Control: no-store** : rien n'est mis en cache par le navigateur ou un proxy.

### 4.4 F4. Authentification des soignants (double facteur)

**Objectif.** Interdire tout accès aux données de santé sans une seconde vérification d'identité.

**Parcours.**

1. Le soignant saisit son identifiant (adresse e-mail ou numéro CIN) et son mot de passe.
2. Le système génère un code à usage unique de 6 chiffres, valable 5 minutes, et l'envoie par e-mail. Aucun jeton d'accès n'est délivré à cette étape.
3. Le soignant saisit le code → il obtient alors son accès.
4. Ce second facteur est exigé à nouveau après 8 heures : au-delà, l'accès aux ressources sensibles est refusé et le soignant est renvoyé vers l'écran de connexion.

**Règles.**

- Le patient, lui, n'est jamais soumis au second facteur (son accès est limité à son propre dossier).
- L'inscription en ligne crée exclusivement des comptes patients : le rôle est forcé côté serveur, il ne peut être influencé par le formulaire.

### 4.5 F5. Ordonnance numérique infalsifiable

**Objectif.** Produire une ordonnance au format PDF, munie d'un code de contrôle impossible à falsifier, vérifiable en pharmacie.

**Parcours médecin.**

1. Après avoir enregistré une consultation, le médecin ouvre l'onglet « Ordonnance ».
2. Un bandeau rappelle les allergies du patient.
3. Le médecin saisit un ou plusieurs médicaments (nom, posologie, durée).

4. Contrôle d'allergie : si un médicament correspond à une allergie connue, la génération est bloquée avec un message explicite (« Le patient est allergique à. . . , médicament concerné : . . . »).
5. Une fois la prescription valide, l'ordonnance est générée : un PDF contenant l'identité du médecin, celle du patient, la date, les médicaments, et un QR code de contrôle.
6. Le patient est notifié ; l'ordonnance est archivée dans son dossier, avec une date d'expiration (3 mois).

#### **Parcours pharmacie.**

1. Le pharmacien scanne le QR code (ou saisit le lien de contrôle).
2. La page de vérification, publique, ne renvoie que deux réponses possibles : ordonnance authentique ou ordonnance invalide / falsifiée. Aucune donnée médicale n'est exposée.

**Règle de sécurité.** Le code de contrôle est une signature cryptographique calculée sur les éléments de l'ordonnance (voir §6.7). Modifier un seul caractère de l'ordonnance invalide la signature.

## **4.6 Fonctions complémentaires**

**Tableau de bord médecin.** Indicateurs (patients en attente, consultations du jour, temps d'attente moyen, ordonnances émises), répartition des priorités, file de triage à valider, espace de consultation intégré (dossier + consultation + ordonnance), agenda du jour.

**Tableau de bord infirmier.** Indicateurs (constantes du jour, admissions, consultations clôturées, alertes stock), taux d'occupation global, capacité par service (lits totaux / occupés / libres, modifiable), inventaire à surveiller avec statut (ok / faible / alerte / critique) et réapprovisionnement.

**Tableau de bord administrateur.** Gestion des utilisateurs (recherche, filtres par rôle, activation/désactivation, changement de rôle), historique des actions, indicateurs du service (taux d'occupation des lits, temps d'attente moyen, taux de réorientation, statistiques de rendez-vous, cas P1 du jour, flux patients), gestion de l'inventaire.

**File de triage temps réel.** Les triages entrants apparaissent instantanément sur les écrans soignants, triés par priorité (P1 → P4), avec les signes d'alarme détectés. Un signal sonore accompagne les cas P1/P2.

**Analyse de documents.** Le patient peut scanner un document médical (ordonnance antérieure, résultat d'analyse) : le texte est reconnu automatiquement puis structuré, et le document est ajouté au dossier.

**Dictée vocale.** Le médecin peut dicter son compte rendu de consultation : la parole est transcrite puis mise en forme automatiquement.

## **5 Architecture technique**

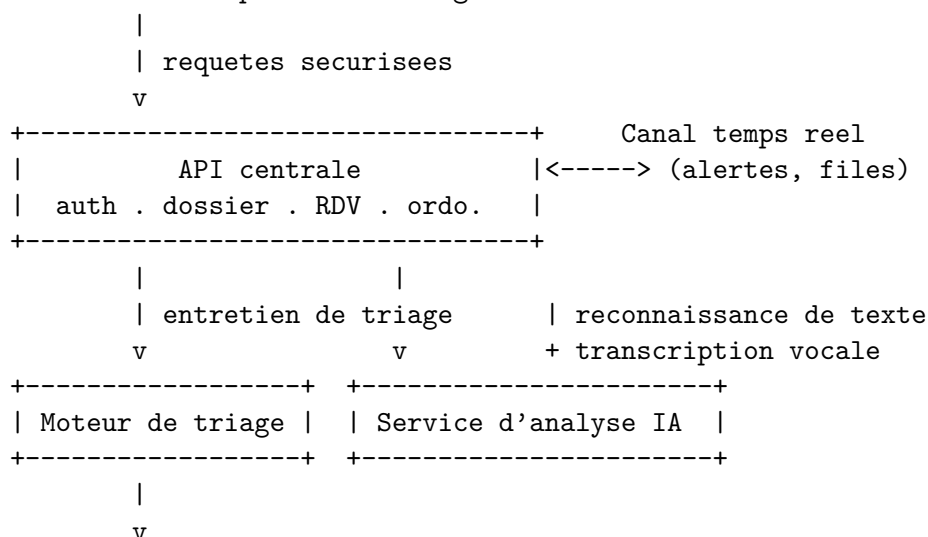
### **5.1 Vue d'ensemble**

SEHHA est un ensemble de quatre composants indépendants qui communiquent par des interfaces réseau. Chacun a un rôle bien délimité.

| Composant                                                | Rôle                                                                                                 | Port (dév.) |
|----------------------------------------------------------|------------------------------------------------------------------------------------------------------|-------------|
| API centrale<br>( <code>sehha-backendV2</code> )         | Authentification, dossier médical, rendez-vous, orchestration du triage, ordonnances, administration | 8000        |
| Moteur de triage<br>( <code>trriage-medical</code> )     | Entretien conversationnel, scoring de gravité, orientation                                           | 8001        |
| Service d'analyse IA<br>( <code>sehha-ai-server</code> ) | Reconnaissance de texte (OCR), transcription vocale, mise en forme par modèle de langage local       | 8002        |
| Interface web<br>( <code>sehha-front</code> )            | Application unique pour les cinq rôles                                                               | 3000        |
| Canal temps réel<br>(intégré à l'API)                    | Diffusion des alertes et mises à jour instantanées                                                   | 8080        |

## Schéma des échanges

Interface web (patients + soignants)



Base de connaissances medicale + modele de langage

Toutes les communications internes entre l'API et les services d'IA sont authentifiées par un jeton partagé.

## 5.2 API centrale

**Socle.** Framework Laravel 12 (PHP 8.2+), base de données PostgreSQL 16. Organisation en couches : contrôleurs (réception des requêtes) → services (logique métier) → dépôts (accès aux données).

### Conventions.

- Toutes les routes sont préfixées par `/api/v1/`.
- Chaque réponse suit une enveloppe uniforme : `{ succès, données, message, méta }` en cas de succès, et `{ succès: faux, erreur: { code, message }, méta }` en cas d'échec. Aucune information technique interne (trace d'exécution) n'est renvoyée au client.
- Les ressources sont désignées par des identifiants publics opaques (UUID) ; les identifiants internes de la base ne sortent jamais de l'API.

**Middleware** (**filtres de requête**). Vérification du rôle, exigence du second facteur pour les rôles sensibles, journalisation d’audit, limitation de débit, en-têtes de sécurité HTTP.

### 5.3 Moteur de triage

**Socle.** Service Python (FastAPI). Il expose un petit ensemble de points d’entrée pour conduire l’entretien : démarrer une conversation, envoyer un message, consulter l’état.

**Fonctionnement.** Voir §6 (Approche IA) pour le détail : entretien mené par un agent, base de connaissances médicale, scoring de gravité, et surtout une chaîne de secours à trois niveaux qui garantit qu’un patient obtient toujours une réponse.

### 5.4 Service d’analyse IA

**Socle.** Service Python (FastAPI). Trois capacités :

- Reconnaissance de texte sur images et PDF (documents médicaux scannés).
- Transcription vocale (dictée des comptes rendus).
- Mise en forme du texte reconnu ou transcrit par un modèle de langage fonctionnant en local, sans dépendance à un service cloud.

### 5.5 Interface web

**Socle.** Application React 19 (TypeScript, Vite), rendue dans le navigateur. Gestion de l’état serveur par cache de requêtes, état local persistant pour la session. Une instance HTTP unique ajoute automatiquement le jeton d’authentification et interprète l’enveloppe de réponse de l’API.

**Navigation par rôle.** Après connexion, l’utilisateur est dirigé vers l’espace correspondant à son rôle ; les zones réservées sont protégées et la session survit au rechargement de la page.

### 5.6 Canal temps réel

L’API diffuse des événements sur des canaux privés (l’abonnement à un canal exige une autorisation, contrôlée par rôle ou par appartenance). Les événements diffusés :

| Événement                        | Destinataires                       | Déclencheur                                |
|----------------------------------|-------------------------------------|--------------------------------------------|
| Mise à jour de la file de triage | Soignants                           | Création ou validation d’un triage         |
| Alerte cas critique (P1/P2)      | Soignants                           | Triage de priorité P1 ou P2                |
| Mise à jour de rendez-vous       | Patient concerné, agenda du médecin | Création / modification / annulation       |
| Alerte stock                     | Infirmier, administration           | Stock passant en statut alerte ou critique |
| Mise à jour de capacité          | Infirmier, administration           | Modification du nombre de lits occupés     |

### 5.7 Base de données

Base PostgreSQL, environ 18 tables regroupées par domaine :

- **Identité** : utilisateurs (rôle, CIN chiffré et haché, secret du code de vérification), jetons d’accès.

- **Structure** : cliniques, services (lits totaux / occupés), profils médecins (agenda, spécialité).
- **Dossier médical** : dossiers patients, allergies, antécédents, consultations, constantes vitales, documents médicaux.
- **Triage / rendez-vous / stocks** : événements de triage, rendez-vous, inventaire.
- **Audit** : historique des actions.

Le choix de PostgreSQL est motivé par le stockage natif de documents structurés (champs JSON) et par la possibilité d'implémenter la piste d'audit au niveau de la base elle-même (voir §6.5).

## 5.8 Choix de conception

| Choix                                                          | Justification                                                                                                                                                |
|----------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Notification par e-mail (et non SMS)                           | Maîtrise des coûts (pas de passerelle opérateur payante), traçabilité intégrée, pas de dépendance à un tiers, journalisation systématique du contenu envoyé. |
| PostgreSQL                                                     | Documents structurés natifs, contraintes fortes, déclencheurs pour l'audit au niveau base.                                                                   |
| Framework Laravel                                              | Écosystème mature pour l'authentification, l'ORM, la génération de PDF et le temps réel ; réduction du code sur mesure sensible.                             |
| Temps réel intégré (et non simple rafraîchissement périodique) | Alerte des cas critiques sans latence ; un mécanisme de secours par rafraîchissement périodique subsiste si le canal temps réel est indisponible.            |
| Modèles de langage avec repli local                            | Le triage reste opérationnel même sans connexion internet (voir §6.5).                                                                                       |
| Chiffrement applicatif des champs sensibles                    | Les données restent illisibles même en cas d'accès direct au fichier de base de données.                                                                     |

## 5.9 Diagrammes

Les diagrammes UML de référence (cas d'utilisation, séquence du parcours triage, classes, architecture) figurent en annexe G. Le diagramme de séquence du parcours de triage est reproduit ci-dessous en version textuelle.

| Patient                 | Interface | API                    | Moteur triage              | Base             |
|-------------------------|-----------|------------------------|----------------------------|------------------|
| decrit ses symptomes -> |           |                        |                            |                  |
|                         |           | démarre l'entretien -> |                            |                  |
|                         |           |                        | questions <-               |                  |
| repond ->               |           | -> message ->          |                            |                  |
|                         |           |                        | ... (boucle)               |                  |
|                         |           |                        | resultat <-                | (score, orient.) |
|                         |           |                        | enregistre le triage ->    |                  |
|                         |           |                        | alerte temps reel si P1/P2 |                  |
| resultat <-             |           | <-                     |                            |                  |

## 6 Approche IA (AI in Healthcare)

### 6.1 Pourquoi un triage conversationnel

Un formulaire figé à questions fixes présente deux limites : il est long à remplir, et il ne s'adapte pas à ce que le patient a déjà dit. SEHHA retient un entretien conversationnel adaptatif : l'assistant décide de la question suivante en fonction des réponses précédentes et du contexte médical du patient (allergies, antécédents, triages récents). L'entretien s'arrête dès que l'information est suffisante, ou immédiatement si un signe d'alarme apparaît.

### 6.2 Déroulé de l'entretien

L'agent suit un cycle simple :

1. **Extraction** : à partir du dernier message, il met à jour les champs cliniques : motif principal, intensité de la douleur, durée des symptômes, évolution, âge.
2. **Décision** : si un signe d'alarme est détecté, l'entretien se termine immédiatement. Sinon, il continue tant que les champs obligatoires ne sont pas tous renseignés ou qu'un nombre minimal d'échanges n'est pas atteint.
3. **Question suivante** : l'agent formule la prochaine question et répond aussi aux éventuelles questions du patient.

Un plafond du nombre d'échanges garantit que l'entretien ne s'éternise pas.

### 6.3 Scoring de gravité

Le score suit une logique inspirée des échelles de tri hospitalières (type Manchester Triage System simplifié), reformulée en priorités P1 à P4 :

- **Court-circuit par signe d'alarme.** Si l'entretien a relevé un ou plusieurs signes d'alarme (douleur thoracique irradiante, signes d'AVC, détresse respiratoire, altération de la conscience, etc.), le score est directement élevé (P1 ou P2) avec une confiance maximale.
- Sinon, le moteur combine la base de connaissances clinique et un raisonnement en plusieurs passes pour produire un score, une orientation et une justification.
- Un seuil de confiance est appliqué : en deçà, le triage est marqué « nécessite une revue humaine ».

Le score est ensuite traduit en priorité, délai recommandé, orientation et message au patient.

### 6.4 Base de connaissances médicale

Le moteur s'appuie sur une base de connaissances construite à partir de documents médicaux de référence, découpés en passages et indexés. Deux ensembles sont distingués : un pour la conduite de l'entretien (quelles questions poser selon le motif), un pour le scoring clinique. L'indexation utilise un modèle de représentation local, sans envoi de données à un service externe.

### 6.5 Dégradation gracieuse : le triage ne tombe jamais en panne

C'est un point différenciant de SEHHA. Le moteur fonctionne en cascade à trois niveaux :

| Niveau | Moyen                                       | Quand       |
|--------|---------------------------------------------|-------------|
| 1      | Modèle de langage performant, dans le cloud | Cas nominal |

| Niveau | Moyen                                                         | Quand                                                           |
|--------|---------------------------------------------------------------|-----------------------------------------------------------------|
| 2      | Modèle de langage local                                       | Le niveau 1 est indisponible (quota, panne réseau, clé expirée) |
| 3      | Moteur de règles déterministe basé sur les mots-clés d'alarme | Les niveaux 1 et 2 sont indisponibles                           |

Le niveau 3, purement local et sans IA générative, détecte quand même les cas critiques à partir d'une liste de mots-clés d'alarme (poitrine, bras gauche, sueurs, paralysie, perte de connaissance...) et force la fin de l'entretien après un petit nombre d'échanges. Résultat : un patient obtient toujours une orientation, même hors ligne.

## 6.6 Garde-fous cliniques

- **Contrôle d'allergie à la prescription.** Avant de générer une ordonnance, le système compare chaque médicament aux allergies connues du patient et bloque la génération en cas de correspondance.
- **Règle « P1 → urgences ».** Un patient trié P1 ne peut pas prendre de rendez-vous : il est renvoyé vers les urgences.
- **Validation humaine obligatoire.** Aucun triage n'est considéré comme définitif tant qu'un médecin ne l'a pas validé (ou corrigé, avec une note de justification).

## 6.7 IA documentaire

- **Reconnaissance de texte.** Les documents scannés par le patient sont analysés (texte extrait), puis un modèle de langage local en structure le contenu (type de document, éléments clés) avant ajout au dossier.
- **Dictée vocale.** Le compte rendu dicté par le médecin est transcrit puis mis en forme automatiquement.

## 6.8 Limites et éthique

- L'IA assiste le tri et la rédaction ; elle ne pose pas de diagnostic et ne prend aucune décision irréversible.
- Chaque triage à faible confiance est explicitement signalé pour revue.
- Le moteur de règles de secours est transparent et déterministe : son comportement est prévisible et auditable.

**Feuille de route.** Les triages validés par les médecins constituent un jeu de données annoté. À terme, ce jeu permettrait d'entraîner un modèle prédictif dédié (forêts aléatoires ou gradient boosting), plus léger et plus rapide que les modèles de langage généralistes, spécifiquement calibré sur la population prise en charge.

# 7 Sécurité et conformité (Cybersecurity & AI)

La sécurité de SEHHA est structurelle : elle intervient à chaque couche, de l'authentification jusqu'à la base de données.

## 7.1 Actifs à protéger et surface d'attaque

| Actif                                                     | Sensibilité                    | Protection principale                   |
|-----------------------------------------------------------|--------------------------------|-----------------------------------------|
| Dossiers médicaux (allergies, antécédents, consultations) | Très élevée                    | Chiffrement + contrôle de rôle + audit  |
| Identités patients (CIN, téléphone)                       | Élevée                         | Chiffrement + hachage pour la recherche |
| Ordonnances                                               | Élevée (risque de contrefaçon) | Signature cryptographique               |
| Comptes soignants                                         | Élevée (accès au DME)          | Double authentification                 |
| Historique des actions                                    | Élevée (intégrité)             | Journal à trois niveaux, non modifiable |

Surface d'attaque considérée : l'API publique, l'interface web, la page publique de vérification des ordonnances, les échanges entre l'API et les services d'IA, et l'accès direct éventuel au fichier de base de données.

## 7.2 Authentification

- **Patients** : identifiant (e-mail ou CIN) + mot de passe → accès direct, limité à leur propre dossier.
- **Soignants** (médecin, infirmier, administrateur, super-administrateur) : identifiant + mot de passe, puis un code à usage unique de 6 chiffres envoyé par e-mail, valable 5 minutes. Aucun jeton n'est délivré avant validation du code.
- Le second facteur est exigé toutes les 8 heures pour l'accès aux ressources sensibles.
- Les mots de passe et les codes de vérification sont hachés (jamais stockés en clair).
- L'interface intercepte l'expiration de session et renvoie l'utilisateur vers la connexion proprement, sans état incohérent.

## 7.3 Autorisation (contrôle d'accès basé sur les rôles)

Chaque route de l'API déclare les rôles autorisés ; un filtre les vérifie avant d'exécuter la moindre logique. Des politiques d'accès ajoutent le contrôle d'appartenance (un patient n'accède qu'à son propre dossier ; un médecin n'agit que dans le périmètre autorisé). La matrice RBAC complète figure en annexe C.

**Extrait :**

| Ressource                  | Patient | Infirmier            | Médecin            | Admin.  |
|----------------------------|---------|----------------------|--------------------|---------|
| Son propre dossier médical | Lecture | —                    | —                  | —       |
| Dossier d'un patient       | —       | Lecture + constantes | Lecture / écriture | Lecture |
| Validation d'un triage     | —       | Oui                  | Oui                | Oui     |
| Émission d'ordonnance      | —       | —                    | Oui                | —       |
| Gestion des comptes        | —       | —                    | —                  | Oui     |

| Ressource              | Patient | Infirmier | Médecin | Admin. |
|------------------------|---------|-----------|---------|--------|
| Historique des actions | –       | –         | –       | Oui    |

## 7.4 Chiffrement des données sensibles

- **Champs chiffrés** (identité CIN, téléphone, substance des allergies, description des antécédents) : chiffrement symétrique AES-256 en mode authentifié. Les données sont stockées chiffrées et déchiffrées uniquement à l’affichage, pour un utilisateur autorisé. Un accès direct au fichier de base ne révèle rien.
- **Recherche sur données chiffrées** : le CIN est également stocké sous forme hachée ; l’authentification par CIN compare des empreintes, sans jamais manipuler le CIN en clair pour la recherche.
- La clé de chiffrement est hors de la base, dans la configuration serveur.

## 7.5 Piste d’audit à trois niveaux

Toute lecture ou modification d’une donnée médicale est enregistrée : qui, quelle action, quelle ressource, quand, depuis quelle adresse IP. La journalisation est redondante, à trois niveaux :

1. **Au niveau de la base de données** : des déclencheurs sur 9 tables sensibles enregistrent automatiquement toute écriture, indépendamment de l’application.
2. **Au niveau de l’API** : un filtre journalise les accès aux ressources du dossier médical.
3. **Au niveau métier** : des enregistrements explicites tracent les opérations importantes (changement de rôle, désactivation de compte, émission d’ordonnance) avec le détail des valeurs modifiées.

L’historique est en ajout seul : il ne peut être ni modifié ni effacé par l’application.

## 7.6 Durcissement applicatif

| Mesure                                          | Effet                                                                                                                                                                          |
|-------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| En-têtes de sécurité HTTP                       | Interdit l’insertion dans un cadre étranger, empêche l’interprétation abusive du type de contenu, restreint l’accès caméra/micro, active le transport strict en HTTPS.         |
| Cache-Control: no-store sur les données patient | Aucune donnée médicale en cache navigateur ou proxy.                                                                                                                           |
| Limitation de débit                             | Deux compartiments séparés (connexion : 20 tentatives/min ; API : 60 requêtes/min), ce qui protège contre l’abus et le devinage de mot de passe sans pénaliser l’usage normal. |
| Enveloppe d’erreur uniforme                     | Aucune trace d’exécution ni détail interne renvoyé au client.                                                                                                                  |
| Politique d’origines croisées restreinte        | Seule l’interface officielle peut appeler l’API depuis un navigateur.                                                                                                          |

## 7.7 Intégrité des ordonnances

Chaque ordonnance porte un code de contrôle qui est une signature cryptographique (HMAC-SHA256) calculée sur l'identifiant de l'ordonnance, l'identité du patient, celle du médecin et la date d'émission, avec une clé secrète connue du seul serveur.

- La page de vérification, publique, recalcule la signature et répond uniquement *authentique* ou *invalidé*. Elle n'expose aucune donnée médicale.
- Toute altération de l'ordonnance (dose, médicament, date) invalide la signature.

## 7.8 Corrections de sécurité intégrées pendant le développement

La démarche de sécurité a été offensive sur notre propre produit. Points identifiés et corrigés :

- **Élévation de privilège via l'inscription** : le formulaire d'inscription ne peut plus influencer le rôle ; tout compte créé en ligne est un compte patient.
- **Unicité réelle du CIN** : le contrôle d'unicité porte sur l'empreinte du CIN, empêchant les doublons d'identité.
- **Robustesse des routes** : les identifiants numériques sont contraints, ce qui supprime une classe d'erreurs sur entrée malformée.

## 7.9 Conformité (loi 09-08 / CNDP)

- Hébergement prévu au Maroc ou en Union européenne.
- Minimisation : la page publique de vérification d'ordonnance n'expose aucune donnée personnelle ; les identifiants internes ne sortent jamais.
- Traçabilité : piste d'audit complète (voir §6.5).
- Droits du patient : accès en lecture à l'intégralité de son dossier ; modification de ses seules coordonnées.

## 7.10 Renforcements prévus pour la mise en production

| Renforcement                                          | Statut                                          |
|-------------------------------------------------------|-------------------------------------------------|
| Expiration effective des jetons d'accès et rotation   | Prévu au déploiement                            |
| Durée de vie stricte du code de vérification          | Prévu au déploiement                            |
| Verrouillage de compte après tentatives infructueuses | Colonnes prêtes, activation prévue              |
| Rotation des secrets de service et gestion par coffre | Prévu au déploiement                            |
| HTTPS/TLS 1.2+ obligatoire sur une URL publique       | Prévu au déploiement (certificat Let's Encrypt) |

# 8 Mise en œuvre et équipe

## 8.1 Démarrage de la plateforme

Prérequis : PostgreSQL, un cache clé-valeur, et l'environnement d'exécution PHP et Python.  
Six processus à lancer :

| # | Composant               | Rôle                                                      |
|---|-------------------------|-----------------------------------------------------------|
| 1 | API centrale            | Sert l'API sur le port 8000                               |
| 2 | Canal temps réel        | Diffusion des événements sur le port 8080                 |
| 3 | Moteur de triage        | Entretien et scoring sur le port 8001                     |
| 4 | Service d'analyse IA    | Reconnaissance de texte et transcription sur le port 8002 |
| 5 | Interface web           | Application sur le port 3000                              |
| 6 | Terminal d'exploitation | Récupération des codes de vérification, maintenance       |

Une base de démonstration propre est obtenue par une commande de réinitialisation avec jeu de données. La procédure détaillée (commandes exactes, ordre de démarrage, vérifications) est fournie dans le fichier `CLAUDE.md` à la racine du dépôt et dans le guide de test.

## 8.2 Organisation du dépôt

```
sehha/
|-- sehha-backendV2/   API centrale (Laravel)
|-- triage-medical/    Moteur de triage (FastAPI)
|-- sehha-ai-server/   Service d'analyse IA (FastAPI)
|-- sehha-front/       Interface web (React)
|-- docs/              Documentation, diagrammes, scenario de demo
'-- CLAUDE.md          Reference d'architecture et procedure d'execution
```

Chaque sous-projet a son propre fichier de dépendances et sa propre configuration.

## 8.3 Feuille de route post-hackathon

1. **Déploiement sécurisé** : hébergement conforme, HTTPS, gestion des secrets par coffre, expiration effective des sessions.
2. **Transferts inter-établissements** : partage contrôlé du dossier entre hôpitaux, carte de capacités temps réel.
3. **Interopérabilité** : alignement sur les standards internationaux d'échange de données médicales.
4. **Modèle prédictif dédié** : entraîné sur les triages validés, plus léger et spécialisé.
5. **Extension fonctionnelle** : téléconsultation, module pharmacie avancé, facturation.

## 9 Annexes

### 9.1 Annexe A. Modèle de données (principales tables)

| Domaine   | Table                                        | Contenu clé                                                                      |
|-----------|----------------------------------------------|----------------------------------------------------------------------------------|
| Identité  | <code>users</code>                           | rôle, CIN (chiffré + haché), téléphone (chiffré), secret du code de vérification |
| Identité  | <code>personal_access_tokens</code>          | tokens d'accès                                                                   |
| Structure | <code>clinics</code> , <code>services</code> | établissement, services et capacité en lits                                      |

| Domaine     | Table             | Contenu clé                                                                 |
|-------------|-------------------|-----------------------------------------------------------------------------|
| Structure   | doctor_profiles   | agenda, spécialité, grade                                                   |
| Dossier     | patient_records   | groupe sanguin, couverture, médecin traitant                                |
| Dossier     | allergies         | substance (chiffrée), sévérité                                              |
| Dossier     | medical_history   | description (chiffrée)                                                      |
| Dossier     | consultations     | motif, diagnostic, traitement, compte rendu                                 |
| Dossier     | vital_signs       | type, valeur(s), caractère anormal                                          |
| Dossier     | medical_documents | type, code de contrôle, texte extrait, résumé                               |
| Triage      | triage_events     | priorité P1–P4, score, symptômes, signes d'alarme, validation               |
| Rendez-vous | appointments      | créneau, statut, lien vers triage éventuel                                  |
| Stocks      | inventory         | produit, quantité, seuil, statut                                            |
| Audit       | audit_logs        | utilisateur, action, ressource, anciennes/nouvelles valeurs, IP, horodatage |

## 9.2 Annexe B. Points d'entrée de l'API (résumé)

Toutes les routes sont préfixées par `/api/v1/`.

| Domaine                       | Points d'entrée principaux                                                                        |
|-------------------------------|---------------------------------------------------------------------------------------------------|
| Authentification              | inscription (patient uniquement), connexion, demande et vérification du code, déconnexion, profil |
| Triage                        | démarrer/poursuivre l'entretien, historique, file de triage (soignants), statistiques, validation |
| Patient                       | dossier, consultations, constantes, documents, mise à jour des coordonnées                        |
| Dossier (soignant)            | consultation du dossier, ajout de constantes (infirmier), consultations et allergies (médecin)    |
| Ordonnances                   | création, historique, PDF, vérification publique                                                  |
| Rendez-vous                   | créneaux, suggestion, création, liste, détail, modification, annulation, liste des médecins       |
| Agenda /<br>dashboard médecin | agenda, indicateurs                                                                               |
| Documents / IA                | liste, détail, reconnaissance de texte, transcription                                             |
| Administration                | comptes, rôles, statut, inventaire, réapprovisionnement, indicateurs, historique des actions      |
| Infirmier                     | capacité (consultation et mise à jour), stocks (consultation et ajustement), indicateurs          |

### 9.3 Annexe C. Matrice RBAC

| Ressource                | Patient            | Infirmier   | Médecin     | Admin  | Super-admin |
|--------------------------|--------------------|-------------|-------------|--------|-------------|
| Réaliser un triage       | Écrire             | Écrire      | Écrire      | —      | —           |
| File de triage           | —                  | Lire        | Lire        | Lire   | Lire        |
| Valider un triage        | —                  | Écrire      | Écrire      | Écrire | Écrire      |
| Son propre dossier       | Lire               | —           | —           | —      | —           |
| Dossier d'un patient     | —                  | Lire        | Lire/Écrire | Lire   | Lire        |
| Constantes vitales       | —                  | Lire/Écrire | Lire/Écrire | Lire   | Lire        |
| Consultations, allergies | —                  | Lire        | Lire/Écrire | Lire   | Lire        |
| Émettre une ordonnance   | —                  | —           | Écrire      | —      | —           |
| Consulter une ordonnance | Lire (les siennes) | —           | Lire        | Lire   | Lire        |
| Rendez-vous              | Gérer (les siens)  | —           | Gérer       | Gérer  | Gérer       |
| Comptes utilisateurs     | —                  | —           | —           | Gérer  | Gérer       |
| Inventaire / capacité    | —                  | Gérer       | —           | Gérer  | Gérer       |
| Historique des actions   | —                  | —           | —           | Lire   | Lire        |

### 9.4 Annexe D. Signes d'alarme du triage (extrait)

Le moteur élève immédiatement la priorité (P1/P2) en présence, entre autres, de :

- douleur thoracique irradiant vers le bras ou la mâchoire, avec sueurs ;
- signes d'accident vasculaire cérébral (asymétrie du visage, faiblesse d'un côté, trouble de la parole) ;
- détresse respiratoire ;
- altération ou perte de conscience ;
- convulsions ;
- hémorragie non contrôlée.

La liste complète, avec la justification clinique, est maintenue dans la base de connaissances du moteur.

## 9.5 Annexe E. Catalogue des événements temps réel

| Événement                  | Canal                                         | Autorisation               | Charge utile              |
|----------------------------|-----------------------------------------------|----------------------------|---------------------------|
| File de triage mise à jour | <code>triage.queue</code>                     | Soignants                  | référence du triage       |
| Alerte cas critique        | <code>triage.p1.alert</code>                  | Soignants                  | priorité, patient         |
| Rendez-vous mis à jour     | <code>patient.{id}, doctor.{id}.agenda</code> | Patient concerné / médecin | référence du rendez-vous  |
| Alerte stock               | <code>inventory.alerts</code>                 | Infirmier, admin           | produit, statut, quantité |
| Capacité mise à jour       | <code>beds.capacity</code>                    | Infirmier, admin           | service, lits occupés     |

## 9.6 Annexe F. Glossaire

| Terme                            | Définition                                                                                                           |
|----------------------------------|----------------------------------------------------------------------------------------------------------------------|
| Triage                           | Évaluation rapide de la gravité d'un patient pour l'orienter vers le bon niveau de soin.                             |
| Priorité P1–P4                   | Échelle de gravité : P1 (urgence absolue) à P4 (non urgent).                                                         |
| CCMU                             | Classification clinique des malades des urgences : échelle de gravité de référence.                                  |
| DME                              | Dossier médical électronique.                                                                                        |
| RAMED                            | Régime d'assistance médicale (couverture santé).                                                                     |
| Double authentification          | Connexion en deux étapes : mot de passe puis code à usage unique.                                                    |
| Signature cryptographique (HMAC) | Code de contrôle qui garantit qu'un document n'a pas été modifié.                                                    |
| Chiffrement AES-256              | Procédé rendant une donnée illisible sans la clé secrète.                                                            |
| Piste d'audit                    | Historique inaltérable de toutes les actions sur les données.                                                        |
| Loi 09-08                        | Loi marocaine relative à la protection des données à caractère personnel ; autorité de contrôle : la CNDP.           |
| RAG                              | Génération assistée par une base de connaissances : le moteur consulte des documents de référence avant de répondre. |